Vulnerabilities Pase_Lista Isste

1. CSP header not set

Description: This header is used as an added layer of security that helps detect and mitigate certain types of attacks like XSS (Cross-Site Scripting) and data injection attacks.

Fix: Ensure the web server, application server, and all components are configured to set the Content Security Policy header.

2. Missing Anti-Clickjacking Header

Description: The response doesn’t protect against “ClickJacking” attacks. Technique: Here, an attacker tricks a user into clicking something different from what they think they’re clicking, and the user thinks they’re interacting with one page, but their clicks are going into another hidden page, and it should include either CSP with the “frame-ancestors” directive. It’s a directive that tells websites whether they are allowed to embed your page inside a <frame> or similar, and it's the standard to defend against clickjacking, as it makes an attacker unable to overlay your page if the browser refuses to render it in their frame) or X-Frame-Options (XFOs are HTTP response headers that tell the browser whether the page may be displayed inside a <frame> or similar

Fix: Modern web browsers support the CSP and X-Frame-Options HTTP headers; ensure one of them is set on all web pages returned by the site. If you expect the page to be framed only by pages on the server, it should use DENY or consider the implementation of the CSP “frame-ancestors” directive.

3. Subresource Integrity Attribute Missing

Description: The integrity module is missing on a script or link tag served by an external server. This tag prevents an attacker who has gained access to the server from injecting malicious content. The integrity attribute enables Subresource Integrity (SRI), where you provide the browser with a hash of the expected file, and the browser refuses to run or apply the resource if the downloaded content doesn’t match.

Fix: Provide a valid integrity attribute to the tag, like sha256 or similar

4. Strict-Transport-Security Header Not Set

Description: HTTP Strict Transport Security (HSTS) is a web security policy mechanism where a server declares that compliant user agents, like web browsers, are to interact with it using only secure HTTPS connections. HSTS is an IETF standards track protocol and is specified in RFC 6797. Without it, a user can be downgraded to plain HTTP, which exposes their traffic to interception and man-in-the-middle attacks.

Fix: Ensure all components are configured to enforce Strict-Transport-Security.

5. X-Content-Type-Options Header Missing

Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to “nosniff.” This allows older versions of IE and Chrome to perform MIME-sniffing, which is when a browser ignores the Content-Type header a server sends and instead inspects the bytes of the response to decide what type of file it is, creating a security risk. It enables XSS via uploaded files, which are script-based attacks, bypassing upload filters and drive-by downloads, where content you wish to display safely could be reinterpreted as something executable or rendered differently than intended.

Fix: Ensure that the App/Web Server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to “nosniff” on all pages, and ensure that the end user uses a standards-compliant and modern eb browser that doesn’t perform MIME-sniffing at all, or that it can be directed by the Web/App Server not to perform MIME-Sniffing